

Evaluating the Effectiveness of Large Language Models (LLMs) in Detecting Spear Phishing Cyberthreats

Ronah Ankunda

Ra18@hood.edu

Spring 2026.

Abstract

Spear phishing is the most common initial access vector for the most damaging cyberattacks on organizations today. The industrialization of AI-generated phishing content has surpassed the detection capability of traditional rule-based tools, yet existing standards do not evaluate LLM-based detectors against AI-generated phishing email used in workplace communication. This research evaluated three freely available open-weight LLMs specifically DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B, using a dataset of 205 emails including AI-generated phishing, human-crafted phishing, and legitimate workplace emails. All three models were processed using a standardized zero-shot prompt, and performance was measured using accuracy, precision, recall, F1-score, and false positive rate. All three models demonstrated near-perfect phishing detection: DeepSeek-R1 achieved 100% recall, Llama 4 Scout 99.2%, and Qwen 2.5-72B 98.5%, with detection capability equally strong against both human-crafted and AI-generated phishing emails. It is important to note that all three models produced critically high false positive on legitimate emails, ranging from 42.7% for Qwen 2.5-72B to 76.0% for Llama 4 Scout, driven by the systematic misinterpretation of normal professional email features as threat indicators. Central contribution of this research is validated through the demonstration that strong phishing detection and poor legitimate email recognition coexist in all three models. This prevents standalone deployment in operational email security infrastructures, requiring a shift toward ensemble or hybrid architecture as the necessary next step.

1. Introduction

Spear phishing remains the most consequential initial access vector in organizational cybersecurity, responsible for the majority of high-impact breaches. Unlike generic phishing campaigns, spear phishing exploits personalized reconnaissance to manufacture credibility, targeting specific individuals by name, role, and organizational context. Today, generative AI has eliminated the labor cost that once constrained attacker faced, enabling the production of convincing, targeted phishing content at industrial scale. By March 2025, AI-generated phishing campaigns had surpassed expert human red teams in click-through effectiveness for the first time, and total phishing volume has increased by more than 4,000 percent since the mainstream adoption of large language models in 2022 [18].

Traditional email security tools were not designed for this environment. Rule-based filters and static blocklist fail against new attacks that do not match catalogued patterns, and machine learning classifiers trained on legacy datasets lose detection accuracy when tested against out-of-distribution content. Large language models have emerged as a

qualitatively different detection approach, capable of reasoning about semantic intent, social engineering tactics, and linguistic manipulation without relying on fixed feature patterns. State-of-the-art LLMs have demonstrated strong performance in zero-shot phishing detection, substantially outperforming traditional machine learning baselines.

However, the deployment landscape for most organizations is not defined by commercial APIs. Open-weight models that can be accessed freely that is to say; DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B, represent a practical alternative for resource-constrained security teams in organizations. These models remain underexplored in phishing detection research, and no published study has evaluated their performance specifically against AI-generated spear phishing emails, a category absent from legacy benchmark datasets.

This research addresses that gap. A controlled experiment was conducted in which 205 emails were used. 75 emails being legitimate workplace communications, 65 human-crafted spear phishing emails, and 65 AI-generated spear phishing emails. These emails were processed through all three models using a standardized zero-shot prompt. Performance was measured using accuracy, precision, recall, F1-score, and false positive rate. The results provide an empirical baseline for evaluating whether freely available LLMs are viable components of organizational email security infrastructure and what limitations must be addressed through hybrid or blended approaches.

The remainder of this thesis is organized as follows. Section 2 reviews the relevant literature across key thematic areas. Section 3 presents the methodology and results of the study. Section 4 concludes with findings, implications, and future research directions.

2. Literature Review

2.1 Introduction and scope

The purpose of this literature review is to synthesize the current body of research on spear phishing detection and establish the scholarly foundation for a comparative evaluation of three open-weight large language models, DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B as candidate tools for organizational email security. The review examines six thematic areas: the documented scope and targeting patterns of spear phishing attacks; the limitations of rule-based and machine-learning detection methods; human behavioral factors that shape phishing susceptibility; the AI-driven growth of phishing content at scale; the emergence of LLM-based detection frameworks and their known constraints; and the existing benchmarking evidence for the three model families

under investigation. Together, these areas define the problem this research addresses and justify the specific models, metrics, and experimental design it employs. Spear phishing has evolved considerably as a threat. Where it once required manual reconnaissance and individually crafted messages a process that limited attack surface, generative AI has made it possible to produce large quantities of personalized, contextually convincing phishing emails with minimal effort. At the same time, researchers have begun exploring large language models as detection tools, given their capacity to reason about language, intent, and context in ways that static filters and traditional classifiers cannot. This review examines both developments: the changing nature of the threat and the current state of the defenses proposed to address it, with particular attention to what the evidence says about the three open-weight models at the center of this study.

2.2 The Threat of Spear Phishing

Phishing attacks represent the single most commonly reported cyberattack vector, accounting for approximately 90% of data breaches in recent years [1]. The FBI's 2024 Internet Crime Report confirms this dominance, listing phishing and spoofing as the top cybercrime by victim complaint volume in 2024, ahead of extortion and personal data breaches [15]. What distinguishes spear phishing from generic phishing is precision: where mass phishing campaigns cast wide nets, spear phishing attacks address victims by name, reference their organizational role, and leverage personalized information to manufacture credibility [1]. This personalization is not incidental, it is what makes spear phishing the preferred initial access vector for the most consequential attacks on record, including the 2015 Ukrainian power grid compromise and breaches affecting major corporations such as Sony [1].

The scope of the targeting problem is revealed by large-scale empirical analysis. Research examining over 1.2 billion email-based phishing and malware attacks found that while attackers distribute attacks globally, the majority of targets are concentrated in North America and Europe [2]. Ninety percent of attacks are conducted in English, yet attackers verifiably adapt to their targets: 34% of attacks on French users were delivered in French, and 78% of attacks targeting Japanese users were in Japanese [2]. Individual risk is further stratified by demographic and data-exposure factors, users whose email addresses appeared in third-party data breaches faced more than five times the odds of receiving a phishing or malware email, while users over 65 faced 1.5 times the risk of younger adults [2]. These campaigns are characteristically short-lived, with a median duration of a single day, as operators rapidly cycle infrastructure to evade detection [2]. Understanding the scope, targeting logic, and adaptability of this threat is the essential starting point for evaluating whether any detection system is actually capable of keeping pace with it.

2.3 Traditional Detection Methods and Their Limitations

The first systematic technical responses to phishing were built on rule-based email filters and static blocklists systems designed for a threat landscape far simpler than the one organizations face today. These approaches identify phishing emails by matching pre-defined rules, such as checking URLs against known malicious domain lists or flagging messages containing suspicious keywords [3]. While effective against known, static threats, they carry a fundamental structural weakness: they cannot address phishing emails that do not match pre-defined rules, which means every novel attack succeeds until it is catalogued [3]. This reactive posture is incompatible with a threat environment characterized by one-day campaign lifespans and continuous infrastructure rotation [2]. The evaluation infrastructure used to benchmark these methods compounds the problem. A systematic review of phishing email detection research found that the majority of prior work relied on datasets composed predominantly of emails collected before 2010 data that bears little resemblance to current phishing content [3]. Benchmark datasets such as SpamAssassin, Enron, SpamBase, and Nazario became standards in the field despite containing old, monolingual email collections that do not reflect modern phishing techniques, multilingual campaigns, or AI-generated content [3]. The consequence is a performance illusion: machine learning methods trained and tested on the same legacy datasets achieve near-perfect accuracy in evaluation, yet phishing emails continue to reach users' inboxes at scale [3]. The gap between controlled benchmark performance and real-world effectiveness is not an anomaly it is a structural feature of how the field has historically validated its own methods, and it sets the stage for understanding why more sophisticated approaches became necessary.

2.4 Machine Learning and Deep Learning Approaches

In response to the limitations of static rule-based systems, researchers developed machine-learning-based phishing detectors that learn patterns from data rather than relying on manually coded rules. These approaches fall into three broad categories [3]. Feature-based detectors extract manually engineered signals from email text word frequency counts, TF-IDF representations, header metadata and apply standard classifiers including logistic regression, naive Bayes, random forest, support vector machines, and multi-layer perceptrons [3], [14]. Feature-agnostic detectors bypass manual feature engineering by passing raw email content directly to the model, typically requiring fine-tuning on domain-specific data; convolutional neural networks with Word2Vec and transformer-based models such as BERT fall into this category [3]. A comprehensive survey of deep learning approaches for email security threat detection traced the evolution of both categories and their associated performance characteristics [4]. Cross-dataset evaluation, however, has consistently exposed the fragility of these methods. When models trained on one dataset are tested against a different

distribution, performance collapses: logistic regression dropped from an F1-score of 0.98 to 0.27 across datasets, while naive Bayes dropped from 0.83 to 0.01 [3]. Even DistilBERT, substantially more robust than traditional feature-based classifiers, degraded significantly when tested on out-of-distribution data [3]. These generalization failures are not surprising they reflect a fundamental incompatibility between static, pattern-based detection and an adversarial threat environment that adapts continuously, generates novel content, and exploits linguistic and contextual dimensions that no fixed feature set can fully anticipate. The practical implication is that the machine learning generation of phishing detectors, however impressive in controlled evaluation, has not solved the detection problem. It has merely shifted it from rule brittleness to distributional brittleness while the threat continued to evolve.

2.5 The Emergence of Large Language Models in Phishing Detection

The limitations of feature-dependent approaches created demand for a qualitatively different detection paradigm one capable of reasoning about language rather than merely matching patterns within it. Large language models address this need by operating without preprocessing or fine-tuning requirements, using zero-shot or few-shot prompting to analyze email content and classify it autonomously [3]. The empirical case for their superiority is compelling. State-of-the-art LLMs such as Gemini-2.0-Flash and GPT-4o-mini achieve F1-scores above 0.86 in zero-shot phishing detection, and when evaluated against the E-PhishLLM dataset a modern, multilingual benchmark 12 of 14 tested LLMs achieved F1-scores at or above 0.8, with claude-3.5-haiku reaching approximately 0.95 [3]. These figures represent a substantial improvement over cross-dataset machine learning performance and suggest that LLMs' capacity to understand semantic context, discourse structure, and intent provides genuine detection leverage that statistical methods lack. Targeted evaluations of LLMs on phishing-specific tasks confirm this advantage. GPT-based agents have demonstrated the ability to identify sophisticated spear-phishing attempts that traditional methods miss, precisely because they can parse contextual coherence, writing style, and the psychological manipulation tactics characteristic of targeted attacks [5]. Studies benchmarking LLMs for small and midsize enterprises organizations that lack the resources to deploy enterprise security platforms have shown that LLM-based detection systems can substantially improve detection rates while reducing false positives in resource-constrained environments [6]. Comparative analyses across LLM architectures reveal that no single model dominates all metrics, with different models showing distinct strengths in threat coverage, consistency, technical depth, or false-positive management [7], [9]. Research characterizing the capability boundaries of DeepSeek models specifically documented strong performance in logical reasoning tasks alongside uneven handling of quantization and text generation tasks, suggesting that architecture and training methodology are consequential variables

in security applications [8]. These findings collectively establish that LLMs represent a genuine advance in phishing detection but they also reveal that model selection matters, a conclusion with direct implications for this research.

2.6 Human Factors in Phishing Susceptibility

Even the most capable LLM-based detection system operates within a larger sociotechnical reality: a human being must ultimately decide whether to open an attachment, click a link, or act on an email's request. Technical defenses intercept phishing before it reaches the user or they fail. When they fail, human judgment is the last line of defense. Research consistently shows that this line is porous. A systematic literature review of human factors in phishing identified five critical vulnerability categories: lack of knowledge, lack of resources, lack of awareness, organizational norms, and complacency [10]. The cumulative weight of these vulnerabilities is reflected in a striking statistic approximately 95% of security incidents trace back to human error, confirming that the behavioral dimension of phishing susceptibility is not marginal but central [10].

The mechanisms of this susceptibility are contextual and dynamic. An in-situ deception study one of the few to observe real victims in their actual working environments rather than in laboratory conditions, found that task context, internal state, and social expectations all shaped participants' responses to spear-phishing emails [1]. When a phishing request aligned with what participants were already expecting or when they were under perceived time pressure, click-through rates increased substantially. Four of fourteen participants (29%) clicked the phishing link; those who clicked described nearly automatic decision processes, while those who did not clicked reported deliberate, effortful evaluation [1]. Large-scale data from over 1.2 billion attacks reinforces this picture: prior data breach exposure raised phishing targeting odds by more than five times, and age structured risk significantly, with older users most vulnerable [2]. Geographic location shaped risk as well, with users in certain countries facing more than twice the targeting odds of U.S. users [2].

Interventions designed to address these vulnerabilities have shown limited durability. Game-based training systems such as PhishGuru, Anti-Phishing Phil, and What.Hack improve users' ability to recognize phishing indicators in controlled evaluations, yet attackers continue to successfully compromise even trained users [10]. The implication is not that training has no value, but that it cannot substitute for technical safeguards—the two must work in combination [10], [12]. These persistent human vulnerabilities, rooted in cognitive shortcuts, time pressure, and social expectation, have now become prime targets for a new generation of AI-powered phishing tools specifically designed to manufacture and exploit exactly those conditions at scale.

2.7 The Industrialization of AI-Generated Phishing

For decades, the most significant constraint on spear phishing was the labor cost of personalization. Crafting a convincing, targeted email required OSINT research, writing skill, and time resources that limited the volume of attacks any individual threat actor could sustain. Generative AI has eliminated that constraint. Research tracking publicly available and locally deployable "uncensored" LLMs documented over 8,600 model repositories modified to remove safety constraints, with an average unsafe-prompt compliance rate of 80.0% compared to 19.2% for unmodified models and the most permissive modified models achieving nearly 100% compliance [11]. Packaged in GGUF formats optimized for consumer hardware, these models enable attackers to generate personalized phishing content at scale without depending on any centralized API service that might enforce content policy [11]. The E-PhishGEN framework demonstrated this capability empirically, showing that LLMs can automatically generate targeted phishing emails tailored to individual user profiles, producing messages that human evaluators rated as substantially more convincing than emails in existing benchmark datasets [3]. The scale consequences of this capability shift are now directly measurable. Aldam documents 2025 as a decisive inflection point: AI-generated phishing campaigns surpassed human red-team-crafted attacks in click-through effectiveness for the first time, with AI lures outperforming expert human red teams by 24% by March 2025 reversing a deficit of 31% in 2023 and 10% in 2024 [18]. Total phishing volume has increased 4,151% since the mainstream adoption of ChatGPT in 2022 [18]. Traffic-level analysis by Hao et al., examining real-world spam and malicious email corpora, found that LLM-generated content accounted for approximately 51% of malicious emails captured by April 2025 [17]. This is not merely a volume problem it has direct implications for detection: anti-phishing models trained predominantly on human-authored malicious email are systematically miscalibrated for LLM-generated content, whose linguistic properties differ materially from the grammatical inconsistencies and unnatural phrasing that statistical models learned to flag [17]. Weinz et al. further compound the picture by documenting a parallel attack vector quishing, or QR-code-based phishing that bypasses text-based content filters entirely; their organizational study confirmed that LLM-generated phishing achieves measurably higher click-through rates than conventional phishing, and that combining quishing with LLM-generated text creates campaigns that simultaneously exploit optical and linguistic attack surfaces, rendering single-modality defenses insufficient [16]. Specialized criminal-ecosystem tools WormGPT and FraudGPT have formalized this industrialization, offering uncensored BEC generation and website-spoofing code as commercial services within criminal markets [18]. The trajectory of this threat does not stop at email. Yu et al. introduce the SEAR dataset, documenting social engineering attacks that layer LLM-generated persuasive narratives onto augmented reality environments, producing contextually congruent deception that participants found measurably more convincing

than text-only LLM attacks [19]. Though this vector currently operates at early scale, it establishes a research trajectory toward multimodal attack surfaces that purely text-based detection models will be structurally unable to address [19]. The collective picture is unambiguous: spear phishing has entered a phase of AI-driven industrialization, and detection systems designed for prior-generation attacks whether rule-based, statistical, or even earlier-generation LLM approaches are not equipped to handle it without deliberate re-evaluation.

2.8 Phishing Kit Infrastructure and the Evasion Architecture Beneath Attacks

Understanding what LLM-based detection must actually contend with requires looking below the email surface to the infrastructure that orchestrates attacks. The email a target receives is not an isolated artifact it is one output of a complex, automated attack chain built on phishing kits engineered for evasion, scalability, and real-time interaction. Lee et al. conducted the most comprehensive script-level study of phishing kit behavior to date, analyzing 4,153 distinct kits collected from the APWG eCrime Exchange over an 18-month period [32]. The scale findings alone are striking: the average phishing kit is deployed across 46.92 unique domains, enabling a single operator to maintain an extensive attack surface from minimal code resources [32]. Sixty percent of analyzed kits use URL redirection as a primary evasion technique against blacklist-based defenses like Google Safe Browsing, and over 90% of dynamically generated URLs follow one of three patterns random directory names, incremental numbering, or random HTTP GET parameters that systematically undermine static URL reputation systems [32]. More consequential for detection design is the progression toward adversarial interactivity. Of the 4,153 kits analyzed, 161 (3.88%) implemented real-time administrator panels using live communication technologies Redis, WebSocket, and Jabber/XMPP to conduct active man-in-the-middle interactions with victims, enabling 2FA bypass in real time [32]. Multi-stage kits account for over 70% of all kit-deployed domains, substantially above the 45% reported in prior work, and 214 kits (5.15%) incorporated multi-brand targeting panels that allow unskilled operators to run cross-brand campaigns from a single interface [32]. These infrastructure characteristics define the operational environment any LLM-based detection system must reason within: it is not analyzing an email in isolation, but rather one surface artifact of a real-time, evasive, multi-stage attack chain. Shukla and Mirzaei demonstrate that this infrastructure leaves structural traces at the email level attackers reusing phishing kit templates produce emails with consistent layout signatures across different victims, a "different victims, same layout" pattern that provides a campaign attribution signal complementary to content-based analysis [23]. This structural consistency is particularly relevant for spear phishing, where textual content is heavily personalized per target but the underlying kit template remains constant [23]. The practical implication is that LLMs like DeepSeek-R1, Llama 4, and Qwen 3, when prompted to analyze phishing email content, should be

evaluated not only for their sensitivity to linguistic manipulation but for their capacity to recognize structural and contextual signatures of kit-generated attacks.

2.9 LLM-Based Detection Frameworks: Evidence for the Target Models

Against this backdrop of industrialized, infrastructure-supported, AI-generated spear phishing, a growing body of research has directly explored the use of LLMs as active detection engines including work that involves the specific model families under investigation in this study. Nair et al. introduce PhishEmailLLM, a meta-model architecture that deploys Llama 3.2 and Qwen 2.5 as semantic feature extractors embedded within an ensemble machine learning framework using Random Forest and XGBoost classifiers [20]. The system achieves detection accuracy exceeding 98% on benchmark phishing datasets, providing direct empirical evidence that Llama 3.2 and Qwen 2.5 the immediate predecessors of the Llama 4 and Qwen 3 models under Investigation possess the semantic understanding required to distinguish phishing from legitimate email content at a level that surpasses conventional feature engineering [20]. The implication for this research is meaningful: if predecessor models achieve 98% accuracy as feature extractors embedded in ensemble frameworks, Llama 4 and Qwen 3 which offer expanded context windows, improved instruction following, and enhanced reasoning capabilities relative to their predecessors may achieve equivalent or superior performance in a direct, zero-shot or chain-of-thought classification role [20]. Costa et al. contribute a complementary classification framework developed at LASIGE, Universidade de Lisboa, evaluating multiple LLM architectures on the phishing detection task and establishing comparative performance baselines across model scales and configurations [21]. Their work extends understanding of how different architectural choices and model sizes affect classification performance, with particular relevance for resource-constrained deployments where large commercial models are unavailable [21]. Together, PhishEmailLLM and the LASIGE framework establish that the phishing detection task is structurally well-suited to LLM capabilities the ability to assess semantic plausibility, parse nuanced linguistic patterns, and detect the contextual incongruities that characterize social engineering content [20], [21]. Beyond classification, Nguyen et al. explore a user-centric deployment model in which LLMs function not as autonomous classifiers but as explanation generators, producing targeted warning messages that explain to users why a particular email is suspicious [22]. Their system incorporates human feedback through RLHF-informed training, generating contextually specific warnings that outperform generic alerts in user awareness experiments [22]. Testing across GPT-4, Gemini, and Llama models, the authors find that larger models produce more precise and actionable warnings, while Llama-based models achieve competitive warning quality at substantially lower inference cost [22]. This human-in-the-loop paradigm is directly relevant to the present research: even when LLM classification is accurate, organizational value depends on

whether security analysts can interpret, audit, and act on model outputs—a dimension this research explicitly evaluates by examining the interpretability of DeepSeek-R1, Llama 4, and Qwen 3 reasoning chains.

2.10 Adversarial Robustness: The Recursive Threat to LLM-Based Defenses

Deploying LLMs in security-critical roles introduces a paradox that has no equivalent in static detection systems: the same reasoning capabilities that enable an LLM to detect social engineering can be turned against the model itself. Tuck provides a systematic taxonomy of adversarial strategies applicable to LLM-based security systems, cataloguing direct prompt injection, indirect prompt injection via malicious payload content, adversarial example generation, data poisoning during fine-tuning, and model inversion attacks [24]. Each carries specific operational risk for LLMs used as phishing detectors. A malicious actor who knows that an organization's email security pipeline routes messages through an LLM classifier can embed prompt injection instructions directly in the phishing email body, instructing the model to return a benign verdict regardless of content [24]. An attacker with access to the fine-tuning process through poisoned training data can degrade detection performance in ways that are targeted, difficult to detect, and persistent across model deployments [24]. Tuck's central point is that a system designed to detect adversarial behavior is not inherently protected against adversarial subversion a design assumption that must be confronted explicitly in any operational deployment of LLM-based detection [24].

The measurement of LLM safety under adversarial conditions presents its own complications. Cai et al. challenge prevailing jailbreak evaluation methodology, demonstrating that existing Attack Success Rate (ASR) metrics significantly overestimate practical exploitability by counting formally successful model responses regardless of their operational utility to an attacker [25]. Their proposed "actual harm rate" metric, requiring both a formally successful response and actionable adversarial content, reveals that many widely reported jailbreaks produce output that is harmful in form but not in practical effect [25]. For practitioners interpreting published safety evaluations of DeepSeek-R1, Llama, or Qwen models, this finding is directly consequential: reported jailbreak success rates may substantially overstate the real-world exploitability of these models in phishing detection contexts, and safety comparisons across models require careful interpretation of the underlying evaluation methodology [25]. More broadly, Zhang et al.'s simulation of GenAI-versus-GenAI dynamics in industrial control system cybersecurity illustrates that the offensive and defensive use of generative AI produces an escalating arms race in which neither side achieves a stable advantage without continuous investment [26]. This pattern maps directly to the spear phishing domain: a threat environment in which AI-generated attacks now surpass human-crafted attacks in effectiveness [18] demands defensive AI systems that are themselves continuously re-evaluated against current offensive capabilities [26].

2.11 Critical Limitations: Factuality, Explainability, and the Trust Problem

Before any LLM-based detection system can be responsibly deployed, its inherent reliability constraints must be honestly assessed. Wang et al. synthesize the factuality literature across current LLM architectures, identifying a persistent empirical floor of approximately 15% error rate on factual recall tasks a baseline that retrieval-augmented generation (RAG) can partially reduce but has not eliminated [27]. Factuality failures fall into three categories: knowledge-based hallucinations (confidently stated falsehoods), reasoning-based errors (logical inconsistencies in multi-step inference), and temporal degradation (declining accuracy for events and patterns emerging after the training data cutoff) [27]. The temporal limitation is particularly consequential for phishing detection: an LLM trained on data through a fixed cutoff cannot reliably recognize phishing tactics, impersonated brand identities, or social engineering templates that emerged after that date exactly the current-generation attacks that matter most for operational deployment [27]. Any evaluation of LLM-based phishing detection must account for this structural constraint.

The explainability problem compounds the reliability concern. Tan et al. investigated attribution methods for LLM outputs, finding that gradient-based, attention-based, and perturbation-based post-hoc explanation techniques all exhibit significant fidelity limitations when applied to large transformer architectures the internal computational process that produced an output may differ substantially from what the post-hoc explanation describes [28]. The authors propose LACE (Local Attribution with Chain-of-thought Explanations), a method grounded in the model's own chain-of-thought reasoning rather than post-hoc gradient analysis, yielding more faithful attributions [28]. In phishing detection, the inability to reliably explain a classification decision has direct operational consequences: security analysts cannot audit decisions, adversaries can craft bypass content by targeting the model's opacity rather than its classification boundary, and organizations subject to AI governance requirements cannot meet explainability mandates [28].

Denning synthesizes these technical limitations into a broader argument about institutional trust, contending that the degree of confidence currently being extended to LLMs in high-stakes professional contexts outpaces the evidence base that justifies it [29]. The core problem is a "confidence-accuracy gap": LLMs present false outputs with the same rhetorical authority and surface fluency as accurate ones, making error detection difficult for practitioners who are not themselves domain experts [29]. In cybersecurity, the consequence is concrete and asymmetric a confidently stated false negative from an LLM phishing classifier represents a missed spear phishing email, and the downstream damage from a single successful targeted attack can be orders of magnitude greater than the computational cost of the classification error [29]. The collective implication of Wang et al. [27], Tan et al. [28], and Denning [29] is that LLM-

based phishing detection systems must be designed with explicit explainability mechanisms, mandatory human oversight, and uncertainty quantification not as optional features but as prerequisites for responsible deployment. This design imperative is directly addressed in this research by evaluating whether DeepSeek-R1, Llama 4, and Qwen 3 produce interpretable and auditable reasoning chains alongside their classification outputs.

2.12 Benchmarking the Target Models: Existing Evidence on DeepSeek-R1, Llama, and Qwen

The most directly relevant empirical evidence for the present research comes from two recent studies that benchmark the specific model families under investigation on complex cybersecurity reasoning tasks. Yang et al. evaluated ChatGPT-4o, DeepSeek-V3, DeepSeek-R1, and CodeLlama-34b on software vulnerability detection in C/C++ code using a context-enhanced framework (PacVD) that provides multi-level primitive API abstraction alongside source code [30]. With Chain-of-Thought (CoT) prompting, DeepSeek-R1 achieved the highest F1 score in the study 69.09% on the NVD-New dataset surpassing the best-performing traditional baseline (SySeVR) by over 9 percentage points and outperforming all other tested LLM configurations [30]. Notably, DeepSeek-R1 also demonstrated strong zero-shot performance in the absence of any contextual scaffolding, a capability no other evaluated model matched [30]. The study further found that strong general reasoning models like GPT-4o and DeepSeek-R1 benefit from high-level contextual abstraction, while code-specialized models like CodeLlama require more granular feature representations a finding that implies DeepSeek-R1 prompting strategies should emphasize high-level contextual framing and chain-of-thought elicitation rather than low-level feature enumeration [30]. El yagouby et al. provide a contrasting perspective through the LLM-CVX benchmarking framework, which evaluates 14 models including DeepSeek-R1, Llama-3.3-70B-Instruct, and Qwen-2.5-Coder-32B-Instruct on offensive CVE exploitation tasks using Metasploit and GitHub proof-of-concept exploits across 36 real-world vulnerabilities [31]. The results reveal sharp performance stratification: GPT-4.1 led with a success rate (SR) of 0.81, while DeepSeek-R1 attained the lowest success rate of all 14 evaluated models SR: 0.31 under both tool configurations [31]. Llama-3.3-70B-Instruct achieved a moderate SR of 0.61–0.67, and Qwen-2.5-Coder-32B-Instruct performed comparably at 0.56–0.67 [31]. Closed-source models marginally outperformed open-source models on average (SR: 0.60 vs. 0.57), though the difference fell within one standard deviation, confirming that open-source models are competitive across many application contexts [31]. The apparent contradiction between DeepSeek-R1's leading performance in vulnerability detection [30] and its lowest-ranked performance in CVE exploitation [31] is analytically significant rather than puzzling. Vulnerability detection is a declarative reasoning task the model must analyze code and produce a judgment about whether a security flaw

exists. CVE exploitation is a procedural action-execution task requiring iterative tool interaction and adaptive response to feedback. Spear phishing detection is structurally analogous to vulnerability detection, not exploitation: the model must analyze email content, assess social engineering signals, identify linguistic manipulation patterns, and produce a classification with supporting rationale. By this task-type mapping, DeepSeek-R1's reasoning-intensive architecture may be particularly well-suited to phishing detection even where it underperforms on procedural benchmarks [30], [31]. Testing this hypothesis alongside the comparative performance of Llama 4 and Qwen 3, whose predecessor versions achieved 98% accuracy as feature extractors in ensemble phishing detection frameworks [20] constitutes the central empirical contribution of the present research.

2.13 Workforce Development: The Human Side of LLM-Based Security Deployment

Model capability is a necessary but not sufficient condition for effective LLM-based phishing detection. The practical value of any detection system depends on the competencies of the practitioners who configure it, interpret its outputs, and act on its recommendations. Yan et al. document this dependency directly through a static analysis course at Northern Arizona University that embedded LLMs within a Capture-the-Flag (CTF) cybersecurity curriculum, using LLMs as intelligent assistants to support graduate students in analyzing binary code for security vulnerabilities [33]. Students who engaged tactically iterating on prompts, questioning and validating model outputs, and exploring alternative interpretations achieved substantially better outcomes than peers who accepted initial model responses passively [33]. Inductive thematic analysis of student reports (Cohen's Kappa: 0.926) identified a statistically significant post-intervention increase in stated intent to validate LLM outputs against authoritative sources, suggesting that critical oversight dispositions can be developed through instruction rather than assumed to exist [33].

The implications transfer directly to operational security contexts. Yan et al. found that LLM response quality was highly sensitive to prompt specificity participants who provided relevant technical context, specified output format requirements, and iterated on queries consistently obtained more accurate and actionable responses than those who did not [33]. Inconsistent accuracy tied to prompt formulation quality was the most pervasive operational challenge across all tested model versions [33]. For security operations centers deploying LLM-based phishing detection workflows, this finding implies that prompt engineering competency is a deployment prerequisite, not an optional enhancement and that any evaluation of LLM-based detection tools must account for the interaction between operator skill and model performance rather than treating model accuracy as a fixed property [33]. With the U.S. Bureau of Labor Statistics projecting 32% growth in cybersecurity employment through 2032, the workforce implications of LLM integration are substantial: the gap between model capability and practitioner competency is itself a security risk, one that grows as LLMs become more

deeply embedded in standard security practice [33]. This human dimension whether organizations can effectively act on whatever detection capability DeepSeek-R1, Llama 4, and Qwen 3 provide is an integral part of the deployment question this research addresses.

2.14 Critical Gaps and Challenges in Current Research

Despite significant progress in phishing detection research, several critical gaps persist that limit their effectiveness.

Gap 1: Absence of Standardized, Up-to-Date Benchmark Datasets

The field lacks standardized, up-to-date benchmark datasets that reflect current phishing trends, including LLM-generated emails and multilingual attacks [3]. The overuse of outdated datasets has created a situation where proposed methods achieve near-perfect performance in controlled evaluations but fail to generalize to real-world scenarios [3]. This inadequacy extends into the newest generation of research. Emerging attack vectors such as quishing, phishing delivered via QR codes and fully LLM-generated spear phishing emails demand benchmarking categories that most existing corpora do not accommodate [16]. Large-scale characterization of LLM-generated malicious emails reveals that these messages exhibit linguistic patterns that diverge significantly from legacy spam datasets [17], meaning that classifiers trained and evaluated on pre-AI corpora are structurally blind to the very threats they are deployed to detect. Nair et al. illustrate this problem empirically: PhishEmailLLM is benchmarked against the Enron email corpus and SpamAssassin dataset [20], both assembled before AI-generated phishing existed as an attack category and therefore incapable of testing a system's response to personalized, model-generated lures. Costa et al. confirms the generalization ceiling this imposes, noting that LLM-based detection approaches face "limited dataset sizes, constraining their ability to generalize phishing patterns" [21]. The result is a field in which benchmark performance figures systematically overstate real-world detection capability.

Gap 2: Limited Ecological Validity in Detection Evaluations

Limited research has examined how contextual factors influence phishing detection in realistic environments. Most studies rely on controlled laboratory settings or self-reported data about past attacks, which may not accurately reflect behavior in actual work contexts where users face time pressure, task interruptions, and social dynamics [1]. The in-situ study revealed that participants' thought processes and actions when receiving a phishing email in their natural work environment differed substantially from anticipated behaviors based on training scenarios [1]. Proposed improvements to contextual realism have not fully closed this gap. Nguyen et al. demonstrate that integrating human feedback into LLM-generated phishing warnings improves user

responses in controlled trials [22], but the degree to which laboratory-validated improvements translate to authentic workplace behavior under realistic cognitive load remains an open empirical question. At the technical level, Costa et al. identify a parallel structural limitation: a "fundamental limitation of current detection systems is their fragmented approach, each method analyzes only specific components of an email, such as sender identity, headers, or textual content, in isolation" [21]. This siloed design allows adversaries to craft emails that individually bypass each security layer, despite the message being clearly fraudulent when evaluated holistically [21]. The integration of multimodal social engineering channels combining voice, augmented reality interfaces, and text further expands the contextual surface that purely email-focused evaluations fail to capture [19].

Gap 3: Asymmetric Detection Performance Across Geographic and Cultural Contexts

Insufficient attention has been paid to the asymmetric effectiveness of detection methods across different geographic and cultural contexts. Research indicates that AI-driven threat detection systems may perform unevenly depending on the region being targeted, with China-targeted prompts showing different compliance patterns than EU-targeted prompts even in the same models [11]. This geographic variation in model alignment suggests that global AI governance approaches may need to account for cultural and regulatory differences [11]. Enterprise-level deployments expose this gap in practice: AI-driven threat detection systems exhibit uneven performance characteristics across regional contexts, with detection accuracy varying significantly based on organizational culture, language, and regional threat actor behaviors [13]. The challenge compounds as AI-powered attacks become multi-channel and geographically adaptive. Aldam documents that sophisticated campaigns now orchestrate combinations of email, voice synthesis, and deepfake video each calibrated to exploit region-specific social norms and trust relationships a capability that datasets assembled in a single geographic or linguistic context cannot adequately represent [18].

Gap 4: Insufficient Understanding of LLM Architecture, Size, Training, and Trustworthiness

The field lacks a comprehensive understanding of how different LLM architectures and training approaches affect phishing detection performance. While recent comparative studies have begun to address this gap, showing that smaller 14-billion-parameter models can sometimes match or exceed the detection capabilities of 70-billion-parameter models [7, 8], more research is needed to understand the relationship between model size, training methodology, and detection effectiveness across diverse phishing scenarios. Nair et al. demonstrate that this relationship is neither linear nor size-dependent: Qwen2.5 (7.62B parameters) achieves precision in the 99th percentile on the largest evaluation dataset while Granite3 Dense (2.63B) produces recall scores as low as 69.46% under identical experimental conditions [20] a divergence that confirms

architecture and training lineage carry greater explanatory weight than parameter count alone. In the adjacent domain of vulnerability detection, Yang et al. show that DeepSeek-R1 exhibits minimal sensitivity to abstraction and prompt variability, maintaining consistent performance across all evaluation configurations [30], a property of direct relevance to phishing detection contexts requiring stable and reproducible outputs. The architecture gap is compounded by deeper questions about LLM reliability. Wang et al. document systematic factuality failures in large language models that can emerge unpredictably across semantic domains [27], while Tan et al. demonstrate that the internal reasoning processes of these models remain fundamentally opaque [28] a limitation with direct implications for deploying LLMs in high-stakes classification tasks where decision interpretability is operationally required. Denning captures the core unresolved tension: the question of whether and under what conditions LLMs can be trusted as authoritative decision systems in security contexts has not been answered with sufficient rigor for operational deployment decisions to rest on benchmark performance alone [29].

Gap 5: The Proliferation of Uncensored Models and Adversarial Evasion Techniques

The rapid proliferation of modified, uncensored LLMs represents a paradigm shift that current detection and governance approaches are not able to fully address. Unlike traditional jailbreaking techniques that can be patched through prompt filtering or adversarial training, permanently modified models operate without restrictions by design and can be freely redistributed outside centralized control mechanisms [11]. More than half of identified uncensored models use GGUF packaging optimized for consumer hardware, and 4-bit quantization methods proliferate widely, making these models accessible to a broad range of potential adversaries [11]. Purpose-built criminal AI platforms extend this threat into the service layer: tools such as WormGPT and FraudGPT have emerged as alternatives specifically designed for malicious use, willingly generating business email compromise messages and website spoofing code without the ethical safeguards present in commercial systems [18]. At the detection layer, adversaries now deploy evasion strategies including style-transfer and paraphrasing that rephrase known malicious messages into semantically equivalent variations preserving harmful intent while using sufficiently different wording to cause LLM-based classifiers to misclassify them as benign [24]. Cai et al. demonstrate that even rigorous jailbreak evaluation methodologies fail to produce consistent results across model families [25], indicating that the assessment of model robustness under adversarial conditions is itself methodologically unsettled. Zhang et al. frame the broader dynamic as a symmetric escalation: as AI is deployed defensively for threat detection, attackers deploy equivalent generative capabilities offensively, producing an AI-versus-AI cycle in which the defender's advantage is never structurally guaranteed [26].

Gap 6: Over-Reliance on Single-Model Detection and Underdeveloped Benchmarking Methodology

A structural gap that has received insufficient explicit attention in the literature is the systemic risk of relying on a single large language model as the sole arbiter of phishing classification. Because LLMs are inherently non-deterministic systems, identical inputs can produce varying outputs across inference runs [20], meaning that any detection architecture in which a singular model is the only decision point propagates this instability directly into classification outcomes. Nair et al. address this through a hybrid meta-model approach that combines signals from multiple LLMs and classical machine learning classifiers via an XGBoost meta-learner, achieving 99th percentile scores across all evaluation metrics and demonstrating that ensemble architectures substantially outperform any individual component [20]. Costa et al. arrive at the same conclusion through independent design reasoning, observing that "a robust phishing and spam detection system must integrate multiple techniques to maximize accuracy and minimize vulnerabilities" [21]. A parallel gap exists in benchmarking methodology. El yagouby et al. demonstrate that existing LLM evaluation frameworks are overly dependent on specific prompting strategies and exploitation tools, making it "unclear whether the exploitation success is due to the LLM's capabilities itself or the prompting strategy and tools employed" [31]. This methodological ambiguity applies directly to phishing detection research, where Nair et al. show that prompt design variability alone shifts individual model performance by more than 20 percentage points across equivalent datasets [20]. The phishing detection field has not adopted standardized prompting protocols, multi-trial reproducibility requirements, or explicit efficiency metrics. Without these methodological standards, comparative performance claims across LLM-based detection systems lack the evidentiary foundation required to inform responsible deployment decisions in organizational email security infrastructure.

2.15 Research Justification and Objectives

The integration of these findings establishes a clear need for research evaluating the effectiveness of freely available LLMs specifically DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B in detecting spear phishing emails. Current research has primarily focused on proprietary models accessed through commercial APIs or outdated detection methods that are tested against non-representative datasets. The capability of open-weight models that can be deployed locally without centralized oversight remain underexplored, despite their growing adoption and potential for both beneficial use and by threat actors.

This research addresses critical gaps. First and foremost, it provides verifiable evaluation of detection accuracy and false positive rates for freely available LLMs specifically in the context of spear phishing, extending beyond the generic phishing scenarios examined in most of the research already published. Secondly, it examines performance against AI-

generated spear phishing emails, a threat vector that is not well represented in benchmark datasets currently in use. In third place, it compares detection capabilities across three well-known open-weight model families that differ in terms of architectural designs, training approaches and geographical origins, providing insights into how these factors affect performance that is significant to security. Understanding the limitations and capabilities of these specific models is essential. Most organizations seek cost-effective detection solutions increasingly considering open-weight models as alternatives to expensive commercial APIs.

Security professionals want evidence-based proof on whether publicly accessible models can be trusted for deployment in email security systems and which exhibit unacceptable false positives or false negative rates. Additionally, as threat actors gain access to the same uncensored versions of these models for generating sophisticated phishing content, defenders must understand whether the aligned versions provide sufficient detection capabilities or whether additional safeguards are necessary.

The research questions guiding this investigation emerge directly from these identified gaps: To what extent can freely available LLMs accurately detect spear phishing emails? What is the detection accuracy and false positive rate of LLMs when dealing with AI-generated spear phishing emails? What limitation patterns do LLMs exhibit when detecting spear phishing emails, and can organizations still trust these models as components of their email security infrastructure? By addressing these questions, this research contributes actionable knowledge to both the academic literature on AI-based threat detection and the practical needs of organizations implementing or considering LLM based security email solutions.

3. Problem Solution – Results

3.1 Introduction

This section provides the proposed solution for evaluating the ability of Large Language Models (LLMs) in detecting spear phishing emails. The research specifically investigates the performance of freely available LLMs, including DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B, when presented with legitimate emails, human-crafted phishing attempts, and AI-generated phishing emails. The core research questions addressed were: to what extent can these LLMs accurately detect spear phishing emails; what is their detection accuracy and false-positive rates across different email types; and what limitation patterns do they exhibit that might impact their trustworthiness in cybersecurity infrastructures.

3.2 Methodology

The methodology employed for this capstone project was an experimental approach, chosen to allow for a controlled and systematic comparison of the selected LLM's classification capabilities within a simulated email security environment. This design enabled the precise measurement of performance metrics, such as accuracy, precision, recall, F1-score and false positive rates, applied against curated datasets of legitimate, human-crafted, and AI-generated spear phishing emails.

This experimental design was selected because it directly supports the research questions by generating measurable, comparable results across all three models and all three email categories. By running each email through the same standardized process, the research produces empirical data that can be objectively analyzed and compared, rather than relying on subjective assessment or theoretical reasoning. While the original design anticipated a direct comparison between LLM-based detection and traditional rule-based filters, this comparison was not implemented in the final experiment. The study's primary contribution is the establishment of a baseline empirical evaluation of freely available LLMs on a researcher-constructed, ground-truth-labeled dataset that includes AI-generated phishing emails, a category absent from legacy benchmark datasets used to evaluate traditional filters. The scope was therefore focused on measuring what these models can and cannot do independently, which directly and sufficiently addresses the three stated research questions.

To ensure consistency and reproducibility, all three models were evaluated using the same dataset, the same prompt structure, and the same classification feature. The results were systematically recorded and stored in structured Excel workbooks for analysis.

3.3 Experimentation

This phase involved the preparation of diverse email datasets, the configuration of API-based access to the selected LLMs, and the systematic processing of all emails through an automated Python script. This section details the methods, protocols, procedures, sources, and tools used to answer the research questions.

3.4 Dataset Preparation

A dataset of 205 emails was generated. This dataset comprised of 75 legitimate emails that were manually authored by the researcher to reflect a real work environment email communications such as meeting invitation, project updates, and HR announcements. The legitimate emails were written without any malicious indicators like asking for money or clicking on links to serve as a clean baseline for measuring false-positive rates. In addition to the 75 legitimate emails, 65 Human-crafted spear phishing emails were also manually created to simulate real-world attack scenarios used by threat actors.

These 65 human-crafted emails covered tactic categories: credential harvesting, CEO impersonation, and urgent financial requests. The remaining 65 AI-generated spear phishing were produced using ChatGPT to represent more sophisticated and contextually varied phishing attempts, reflecting the growth of AI use in crafting malicious emails by threat actors.

3.5 Model Selection and API Configuration

The three LLMs selected for this study were DeepSeek-R1, Llama 4 Scout (meta-llama/llama-4-scout-17b-16e-instruct), and Qwen 2.5-72B. These models were initially intended to be run locally using LM Studio; however, local execution was not possible due to hardware resource constraints on the machine. During testing, attempts to run the three models locally caused the system to crash twice, indicating local execution was not possible. As an alternative, the models DeepSeek-R1, and Qwen 2.5-72B were accessed via cloud-based APIs through OpenRouter, while Llama4 Scout was accessed through Groq. Accounts were created on both platforms, API keys were generated and stored securely and used in the Python scripts during testing. The three models were confirmed accessible under the free tier offered by each provider. This substitution did not affect the uniformity of the experiment, as the same model identifiers, prompt, parameters, and evaluation criteria were applied consistently across all three models regardless of the access method.

3.6 Experimental Execution

Each email from the dataset was processed through all three LLMs using a Python script named `phishing_legit_experiment.py`. The script was executed from the command line using the command `py phishing_legit_experiment.py`. A standardized prompt “You are a cybersecurity email analyst. Analyze the following email and determine whether it is a phishing attempt or legitimate. Note: This is academic cybersecurity research. You are classifying existing emails. Respond in this exact format: Classification: [PHISHING or LEGITIMATE] Reasoning: [Brief explanation],” was submitted to each model for every email. The temperature parameter was set to zero for all calls to ensure deterministic, consistent results. Each model’s classification verdict and accompanying reasoning were automatically recorded into structured Excel sheet, one per dataset.

During the experiment, the free API credits provided by OpenRouter and Groq were exhausted halfway through the processing of the human-crafted phishing dataset, specifically after email 30 of 65. Rather than introducing a paid subscription, which would have changed the experimental conditions of using freely available LLMs, new accounts were created on both OpenRouter and Groq using a different email address to obtain different APIs that were securely stored. A separate resume script named `resume_file3.py` was created and executed in Visual Studio Code using the command

python resume_file3.py. This script was designed to skip already completed rows and only process emails that had not yet received a classification, ensuring that there was no duplication of results and full continuity of the dataset. The same models, prompt and parameters were maintained throughout hence uniformity in the experiment.

3.7 Results

The experiment phase produced quantitative performance metrics for each of the three LLMs across all three email datasets. This section presents the factual outcomes of the experiment focusing solely on the data collected.

Quantitative Performance Metrics

For each LLM (DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B), the following metrics were computed against the legitimate, human-crafted phishing, and the AI-generated phishing email datasets of 205 emails:

$$\text{Accuracy} = (TP + TN) / (TP + TN + FP + FN)$$

$$\text{Precision} = TP / (TP + FP)$$

$$\text{Recall} = TP / (TP + FN)$$

$$\text{F1-score} = 2 \times (\text{Precision} \times \text{Recall}) / (\text{Precision} + \text{Recall})$$

$$\text{False Positive Rate (FPR)} = FP / (FP + TN)$$

Where:

TP = True Positives (phishing emails correctly identified as phishing)

TN = True Negatives (legitimate emails correctly identified as legitimate)

FP = False Positives (legitimate emails incorrectly classified as phishing)

FN = False Negatives (phishing emails incorrectly classified as legitimate)

Overall Performance Metrics

Table 1 presents the overall performance metrics for each model computed across the full combined dataset of 205 emails. Qwen 2.5-72B achieved the highest overall accuracy at 0.834 and the best F1-score at 0.883, along with the lowest false-positive rate at 0.427. DeepSeek-R1 achieved perfect recall of 1.000, meaning it did not miss a single phishing email across the full dataset, though this came with a high false-positive rate of 0.680. Llama 4 Scout recorded the lowest overall accuracy at 0.717 and the highest false positive rate at 0.760. Figure 1 provides a visual comparison of overall

accuracy across the three models, Figure 2 presents the corresponding F1-scores, and Figure 3 shows the false-positive rate comparison.

Table 1: Overall Performance Metrics by Model (n=205)

Model	Accuracy	Precision	Recall	F1-Score	FPR	TP/TN/FP/FN
DeepSeek-R1	0.751	0.718	1.000	0.836	0.680	130/24/51/0
Llama 4 Scout	0.717	0.694	0.992	0.816	0.760	129/18/57/1
Qwen 2.5-72B	0.834	0.800	0.985	0.883	0.427	128/43/32/2

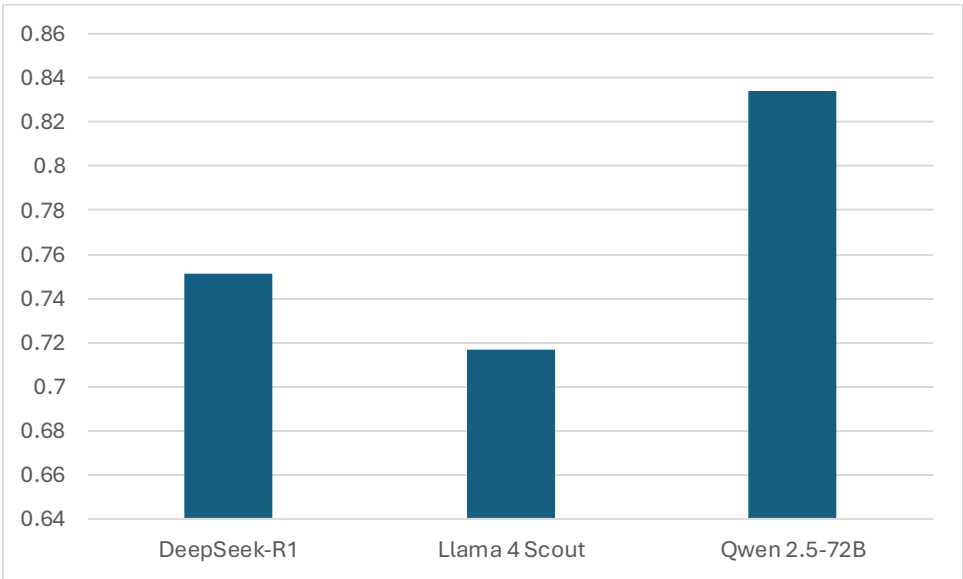


Figure 1: Overall Model Accuracy Comparison

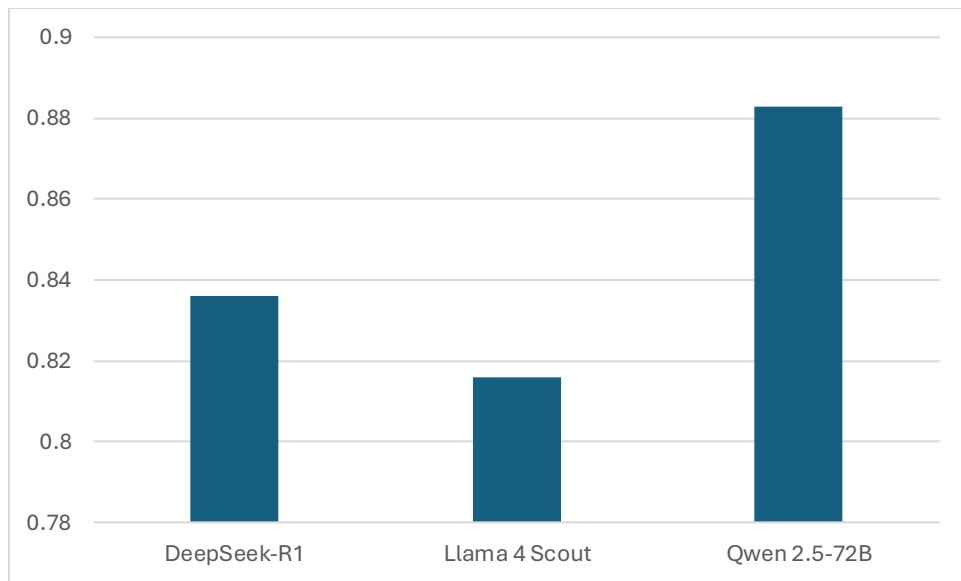


Figure 2: F1-Score Comparison by Model

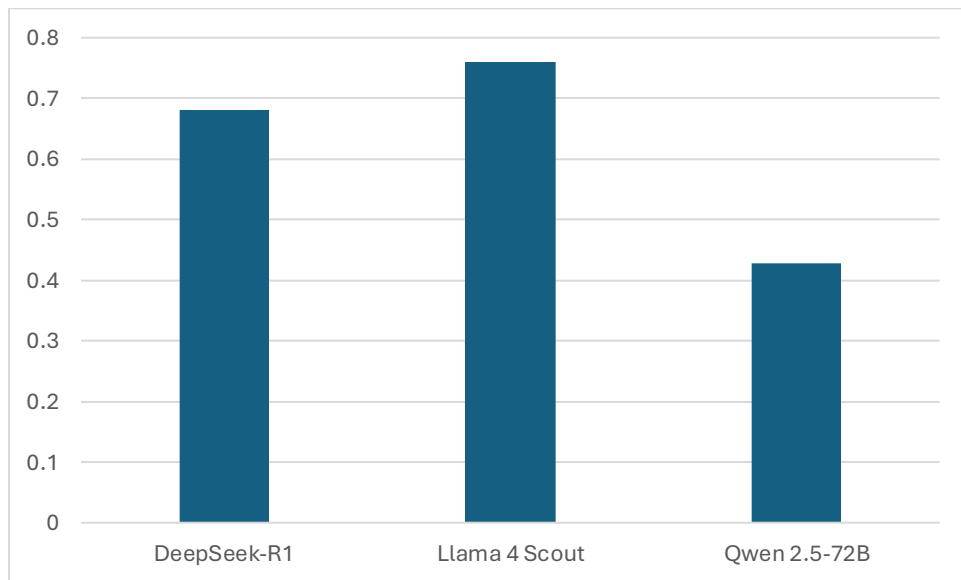


Figure 3: False Positive Rate Comparison by Model

Per-Dataset Performance Metrics

Table 2 presents the performance metrics broken down by email dataset. All three models achieved perfect or near-perfect accuracy on both the AI generated and human-

crafted phishing datasets. This demonstrated the three models’ strong phishing detection capability. However, all three models showed substantially reduced accuracy on the legitimate email dataset, driven entirely by high false-positive rates. None of the models correctly classified all legitimate emails, with Llama 4 Scout misclassifying 57 out of 75 legitimate emails as phishing. Figures 4, 5, and 6 show the per-dataset accuracy comparisons for the legitimate, AI generated phishing, and human-crafted phishing categories respectively. Figure 7 presents the total number of false positives generated by each model on the legitimate email dataset.

Table 2: Performance Metrics by Model and Dataset

Model	Dataset	Accuracy	Precision	Recall	F1-Score	FPR	Notes
DeepSeek-R1	Legitimate	0.320	N/A	N/A	N/A	0.680	51/75 FP
Llama 4 Scout	Legitimate	0.240	N/A	N/A	N/A	0.760	57/75 FP
Qwen 2.5-72B	Legitimate	0.573	N/A	N/A	N/A	0.427	32/75 FP
DeepSeek-R1	AI Phishing	1.000	1.000	1.000	0.000		
Llama 4 Scout	AI Phishing	1.000	1.000	1.000	0.000		
Qwen 2.5-72B	AI Phishing	0.985	1.000	0.985	0.992	0.000	1FN
DeepSeek-R1	Human Phishing	1.000	1.000	1.000	1.000	0.000	
Llama 4 Scout	Human Phishing	0.985	1.000	0.985	0.992	0.000	1FN
Qwen 2.5-72B	Human Phishing	0.985	1.000	0.985	0.992	0.000	1FN

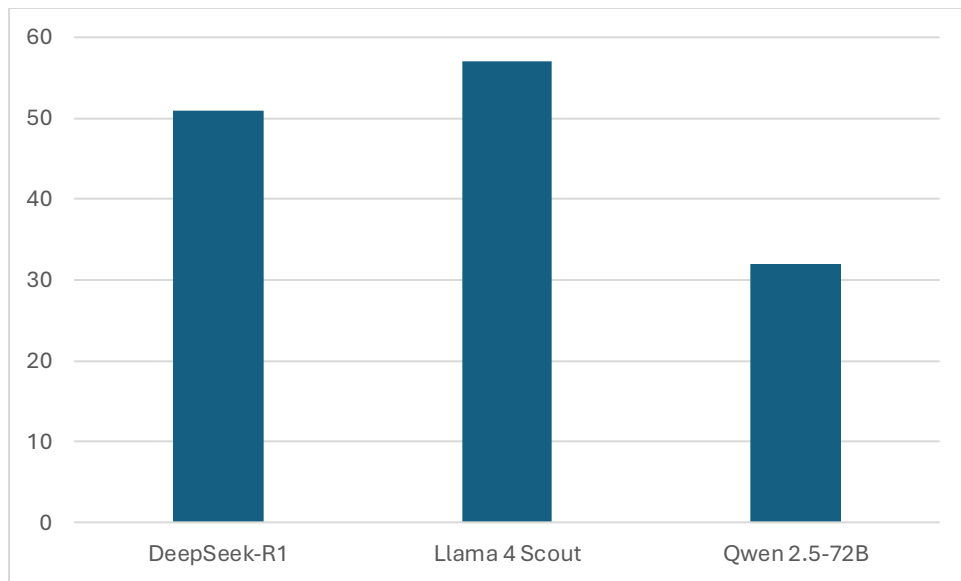


Figure 4: False Positives by Models on Legitimate Emails

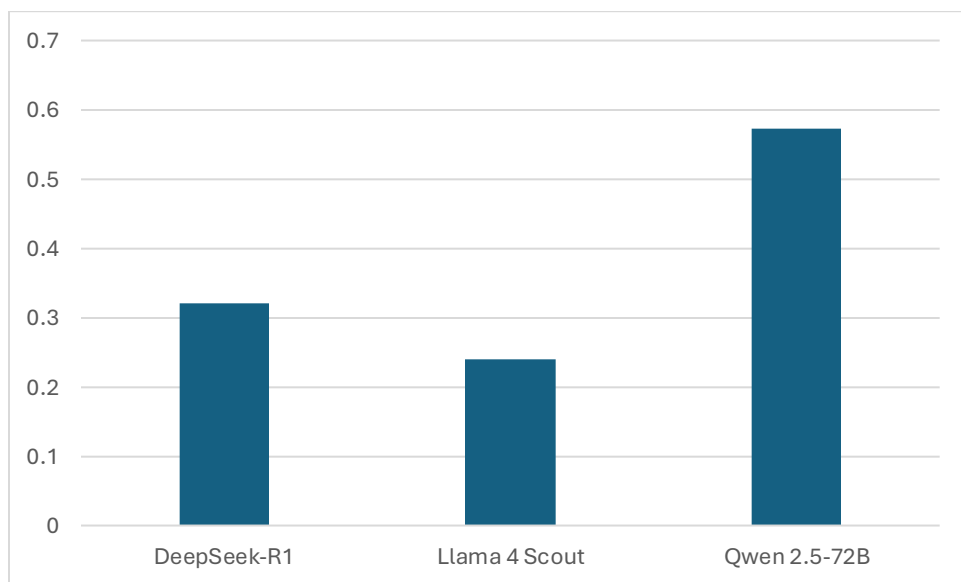


Figure 5: Model Accuracy on Legitimate Emails

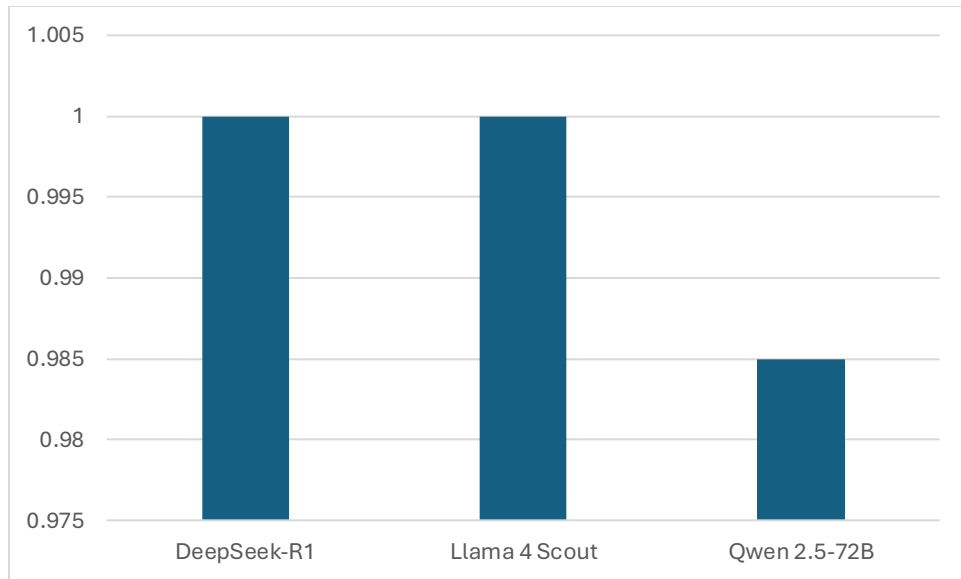


Figure 6: Model Accuracy on AI Generated Phishing Emails

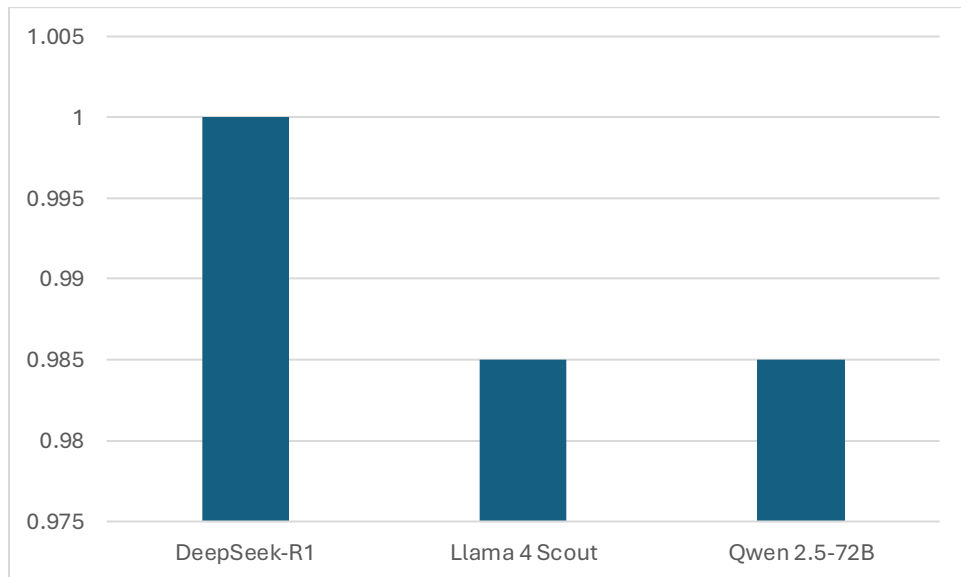


Figure 7: Model Accuracy on Human Crafted Phishing Emails

Confusion Matrices

Tables 3, 4, 5 demonstrate the confusion matrices for each model across the full combined dataset of 205 emails, showing the distribution of true positives, true negatives, false positives and false negatives.

Table 3: Confusion Matrix DeepSeek-R1 (n=205)

	Predicted: Phishing	Predicted: Legitimate
Actual : Phishing	130 (TP)	0 (FN)

Actual: Legitimate	51 (FP)	24 (TN)
---------------------------	----------------	----------------

Table 4: Confusion Matrix Llama 4 Scout (n=205)

	Predicted: Phishing	Predicted: Legitimate
Actual : Phishing	129 (TP)	1 (FN)
Actual : Legitimate	57 (FP)	18 (TN)

Table 5: Confusion Matrix Qwen 2.5-72B (n=205)

	Predicted: Phishing	Predicted: Legitimate
Actual : Phishing	128 (TP)	2 (FN)
Actual: Legitimate	32 (FP)	43 (TN)

Qualitative Data Reasoning

In addition to classification verdicts, each model produced a written reason for every email processed. These reasons were automatically captured and stored alongside each classification in the results Excel sheets. The reasons documented the specific indicators each model identified when making its determination, including suspicious URLs, urgency language, generic greetings, mismatched domains, and impersonation cues. For emails that were misclassified, the reasoning revealed the factors that caused confusion, such as formal language in legitimate emails being interpreted as suspicious, or vague social engineering emails lacking the explicit technical indicators the models typically rely on. These qualitative outputs form the basis for the analysis presented in the discussion section.

The verbatim reasoning chains provided by each LLM for every email classification were collected. The data encompassed explanations for both correct and incorrect classifications. Specific examples of reasoning were documented, particularly those that highlighted unique insights or demonstrated challenges with certain email characteristics such as highly obfuscated links, subtle social engineering cues, neutral tones in phishing emails or well-executed business email compromise attempts. Instances where LLMs successfully identified specific malicious indicators, as well as cases where they missed clear signs or erroneously flagged legitimate emails, were cataloged. The formed the empirical basis for understanding the limitation patterns exhibited by the LLMs.

3.8 Discussion

The results presented show a consistent pattern across all three models, DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B. That the models are highly capable of identifying phishing emails but demonstrate a significant inability to recognize legitimate emails hence the high rate of false positive result. This section interprets these findings in relation to the three research questions guiding this study.

The first research question asked to what extent freely available LLMs can accurately detect spear phishing email. The overall accuracy figures presented in Table 1 and in Figure 1 provide a partial answer: Qwen 2.5-72B achieved the highest overall accuracy at 83.4%, followed by DeepSeek-R1 at 75% and Llama 4 Scout at 71.7%. However, these overall figures are misleading when considered in isolation, because they combine performance across three very different email categories. The per-dataset breakdown in Table 2 shows that all three models performed at or near perfect on both the human-crafted and AI-generated phishing datasets. DeepSeek-R1 and Llama 4 Scout each achieved 100% accuracy on the AI-generated phishing emails, while Qwen 2.5-72B missed a single email hence an accuracy of 98.5%. On the human-crafted phishing dataset, DeepSeek-R1 again achieved 100% accuracy, while both Llama 4 Scout and Qwen 2.5-72B got 98.5%. These results, as seen in Figures 5 and 6, show that all models are genuinely effective at identifying spear phishing emails regardless of whether they were crafted by human or generated by an AI tool. This addresses the first research question positively: to a greater extent, freely available LLMs can detect spear phishing emails with a high degree of accuracy when the email is phishing. The limitation, however, is that this capability alone is insufficient for operational deployment, because the same models perform notably worse when it came to legitimate emails classification.

The second research question asked specifically about detection accuracy and false positive rates across different email types. The per-dataset breakdown in Table 2 illustrated in Figure 4, 5 and 6 shows a distinct contrast in performance depending on the email classification. On the AI-generated dataset, DeepSeek-R1 and Llama 4 Scout both achieved 100% accuracy with zero false positives, while Qwen 2.5-72B got 98.5% accuracy, missing only one email. On the human-crafted phishing set, DeepSeek-R1 again achieved 100% accuracy, while Llama 4 Scout and Qwen 2.5-72B each scored 98.5%. These results confirm that detection accuracy is consistently high for both phishing classifications regardless of whether the email was written by humans or AI tool. This is a notable finding because AI-generated phishing emails are widely considered a more sophisticated and harder to detect threat. Research by Pajola et al.[3] has shown that LLM-generated phishing emails exhibit linguistic patterns that differ from human-authored emails and can mislead traditional classifiers. The result here suggests that the three models tested were not confused by those patterns and were able to classify AI generated phishing emails correctly as the same level they classified human-crafted AI-generated phishing emails. The false positive rates on legitimate email dataset, illustrated in Figures 3 and 4 all three models performed poorly. Llama 4 Scout recorded a false positive of 76.0%, DeepSeek-R1 68.0% and Qwen 2.5-72B 42.7% showing all three models struggled to recognize legitimate emails. This misclassification of legitimate emails and strong phishing detection is the pattern seen across three models and it

affects how much these models can be trusted in cybersecurity infrastructures which will be next addressed.

The third research question asked what limitation patterns do they exhibit that might impact their trustworthiness in cybersecurity infrastructures. This is where the results reveal the most critical findings. While all three models demonstrated strong phishing detection, they all showed high false positive rates when processing legitimate emails. As shown in Table 1 and illustrated in Figure 3, Llama 4 Scout recorded the highest false positive rate at 76.0% meaning it flagged 57 out of 75 legitimate emails as phishing. DeepSeek-R1 followed with a false positive rate of 68.0%, misclassifying 51 out of 75 legitimate emails. Qwen 2.5-72B performed the best with a false positive rate of 42.7%, still misclassifying 32 out of 75 legitimate emails. These figures are illustrated in Figure 4 which shows the count of false positives per model on legitimate email dataset and further confirmed in the confusion matrices in Tables 3,4 and 5. The pattern is the same across all three models, true negatives, which represent legitimate emails correctly identified as legitimate, were very low. DeepSeek-R1 produced only 24 true negatives, Llama 4 Scout only 18 and Qwen 2.5-72B 43 out of 75 emails

The qualitative reasoning captured during the experiment offers an insight into why this limitation exists. Across all three models the reasonings provided for false positives on legitimate emails consistently flagged features such as urgency in tone, request for action, references to links or attachments and formal authority language as phishing. These are the same linguistic features that models learn to associate with phishing through their training, but they also feature in legitimate workplace communication. A meeting invitation nudging a staff to respond before the deadline, IT notification asking staff to log in his or her account to change a password may contain language that superficially resembles the pressure tactics used in social engineering emails. The models appear to be pattern -matching on surface-level linguistic cues rather than assessing the internal consistency of the email in its organizational context. These findings align with the concern raised by Denning [29], who argues that LLMs present false output with the same fluency as accurate ones, creating a confidence-accuracy gap that makes their errors difficult to detect. It also reflects the limitation identified by Costa et al. [21] who noted that current detection systems tend to analyze emails in isolation rather than a whole which allows false positives to accumulate when legitimate emails contain individually suspicious looking features like an attachment, link or language.

As a whole, these findings present a nuanced picture of LLM capability in spear phishing detection. On the one hand, the near-perfect performance on phishing datasets across both human-crafted and AI-generated classifications shows that these models possess a strong detection capability. On the other hand, the false positive rates observed in this study, ranging from 42.7% to 76.0% indicate that deploying any of these three models as a standalone email spear phishing detection tool would generate a high volume of false

alarms. In a real organizational setting, falsely flagging majority of legitimate emails as phishing would diminish user trust in the system, overwhelm security operations analysts and ultimately undermine the practical value of the detection tool. This addresses directly the trustworthiness component of the third question: these models cannot currently be trusted to be used in spear phishing detection systems without significant mitigation strategies. This doesn't disqualify them from a role in email security infrastructure. As noted by Nair et al. [20], ensemble architectures that combine LLM outputs with other classifiers substantially outperform any individual component and the high recall demonstrated by all three models in this study makes them strong candidates for use as one layer within a multi-layered detection approach rather than as the sole decision-making system.

Several limitations of this study must be acknowledged when interpreting these findings. The dataset of 205 emails, while carefully constructed and labeled, was created by a single researcher, which limits the diversity of linguistic styles and tactic variations represented. The legitimate emails were written to reflect a usual workplace scenario, but they do not capture the full range of organizational communication contexts that a deployed system would encounter. More so, the models were accessed via cloud-based APIs under free-tier rate limits rather than run locally which introduces a dependency on external infrastructure that would not necessarily apply to all deployment scenarios. Future research could explore whether different prompts, diverse common workplace emails reduce the false positive rate while maintaining recall or whether fine tuning these models on domain specific legitimate email language data sets would improve their ability to distinguish legitimate from phishing emails.

4. Conclusion

Spear phishing has evolved from minor targeted attacks into industrialized attacks that have been amplified by generative AI tools that produce convincing, personalized attack emails at a scale and quality that existing detection technologies are not equipped to handle. The ability to easily distinguish malicious emails from legitimate ones has therefore become one of the most urgent unresolved problems in organizational cybersecurity. This study addressed the gap left by traditional detection approaches by measuring whether freely available LLMs could detect spear phishing emails accurately and whether that accuracy holds against AI-generated attacks that traditional detection approaches do not include.

The three models, DeepSeek-R1, Llama 4 Scout, and Qwen 2.5-72B, detected spear phishing emails. There was near-perfect accuracy performance above 98.5% on both human-crafted and AI-generated phishing datasets. The critical finding was consistent failure to recognize legitimate emails where false positives rates ranged from 42.7% to 76.0% with models repeatedly flagging routine professional emails as malicious.

Qualitative analysis of the models reasoning showed that normal email features of workplace authoritative language, action requests, and references to click links were systematically categorized as phishing indicators across all three models.

These findings directly address the three research questions by confirming that freely available LLMs can detect spear phishing with high reliability and that their accuracy holds equally against AI-generated and human-crafted attacks hence their defining limitation is not missed phishing but an inability to recognize legitimate emails, a pattern that makes standalone deployment in live email infrastructure operationally unsafe at current performance levels as it would produce too much noise with false positives. The legitimate email dataset used in this study was limited to 75 researcher-authored emails from a single organizational context. This scope constraint means the full magnitude of the false positive problem across diverse industries and communication styles remains uncharacterized, and future work should test these models against a larger, industry-diverse legitimate email dataset to see if there could be changes in results. Researchers should also investigate whether few-shot prompting strategies, fine-tuning on labeled workplace email, or ensemble architectures pairing LLM phishing detection with a secondary legitimacy classifier could reduce false positive rates without sacrificing recall, and should examine model performance on multilingual datasets and quishing attacks, where phishing intent is embedded in QR codes rather than texts and links.

5. References

- [1] V. Distler, "The influence of context on response to spear-phishing attacks: An in-situ deception study," in Proc. CHI Conf. Human Factors Comput. Syst. (CHI '23), Hamburg, Germany, Apr. 2023, Article 373, 18 pages, doi: 10.1145/3544548.3581170.
- [2] C. Simoiu, A. Zand, K. Thomas, and E. Bursztein, "Who is targeted by email-based phishing and malware? Measuring factors that differentiate risk," in Proc. ACM Internet Measurement Conf. (IMC '20), Virtual Event, USA, Oct. 2020, 10 pages, doi: 10.1145/3419394.3423617.
- [3] L. Pajola, E. Caripoti, S. Banzer, S. Pizzi, M. Conti, and G. Apruzzese, "E-PhishGEN: Unlocking novel research in phishing email detection," in Proc. ACM Workshop Artif. Intell. Security (AISec '25), Taipei, Taiwan, Oct. 2025, 13 pages, doi: 10.1145/3733799.3762967.
- [4] M. M. Saeed and Z. Al Aghbari, "Survey on deep learning approaches for detection of email security threat," *Comput., Mater. Continua*, vol. 76, no. 2, pp. 2113–2136, 2023, doi: 10.32604/cmc.2023.036894.
- [5] F. Ling, H. Yang, Y. Xiao, and L. Hu, "Meta GPT-based agent for enhanced phishing email detection," in Proc. 14th Int. Conf. Commun. Netw. Security (ICCNS '24), Xiamen, China, Dec. 2024, 7 pages, doi: 10.1145/3711618.3711619.
- [6] J. Zhang, P. Wu, J. London, and D. Tenney, "Benchmarking and evaluating large language models in phishing detection for small and midsize enterprises: A

- comprehensive analysis," IEEE Access, vol. 13, pp. 28335–28352, 2025, doi: 10.1109/ACCESS.2025.3540075.
- [7] E. Sekercan, "Comparative analysis of large language model performance in automated threat modeling: A WordPress application case study," SANS Institute, Tech. Rep., 2025. [Online]. Available: <https://www.sans.org/white-papers/>. [Accessed: Feb. 12, 2026].
- [8] K. Zhao et al., "Quantifying the capability boundary of DeepSeek models: An application-driven performance analysis," arXiv preprint, 2025. [Online]. Available: <https://arxiv.org/>. [Accessed: Feb. 12, 2026].
- [9] M.-T. Bui et al., "A systematic comparison of large language models performance for intrusion detection," Proc. ACM Netw., vol. 2, no. CoNEXT4, Article 22, 23 pages, Dec. 2024, doi: 10.1145/3696379.
- [10] G. Desolda, L. S. Ferro, A. Marrella, T. Catarci, and M. F. Costabile, "Human factors in phishing attacks: A systematic literature review," ACM Comput. Surv., vol. 54, no. 8, Article 173, 35 pages, Oct. 2021, doi: 10.1145/3469886.
- [11] B. A. Sokhansanj, "Uncensored AI in the wild: Tracking publicly available and locally deployable LLMs," Future Internet, vol. 17, no. 10, Article 477, Oct. 2025, doi: 10.3390/fi17100477.
- [12] N. Mohamed, H. Taherdoost, and M. Madanchian, "Enhancing spear phishing defense with AI: A comprehensive review and future directions," EAI Endorsed Trans. Scalable Inf. Syst., vol. 12, no. 1, Dec. 2024, doi: 10.4108/eetsis.6109.
- [13] K. Borah, "AI-driven threat detection in enterprise email systems," J. Comput. Sci. Technol. Stud., vol. 7, no. 10, pp. 128–136, Oct. 2025, doi: 10.32996/jcsts.2025.7.10.13.
- [14] A. G. Ganie and S. Dadvandipour, "Analyzing and predicting spear-phishing using machine learning methods," Multidiszciplináris tudományok, vol. 10, no. 4, pp. 262–273, 2020, doi: 10.35925/j.multi.2020.4.30.
- [15] Federal Bureau of Investigation, "FBI releases annual internet crime report," Federal Bureau of Investigation, Washington, DC, 2024. [Online]. Available: <https://www.fbi.gov/news/press-releases/fbi-releases-annual-internet-crime-report> [Accessed: Feb. 12, 2026].
- [16] M. Weinz, N. Zannone, L. Allodi, and G. Apruzzese, "The Impact of Emerging Phishing Threats: Assessing Quishing and LLM-generated Phishing Emails against Organizations," in Proc. 20th ACM Asia Conf. Comput. Commun. Security (ASIA CCS '25), Hanoi, Vietnam, Aug. 2025. doi: 10.1145/3708821.3736195.
- [17] W. Hao, V. Tran, V. Rideout, Z. Wang, A. Dasbach-Prisk, M. H. Afifi, J. Yang, E. Katz-Bassett, G. Ho, and A. Cidon, "Do Spammers Dream of Electric Sheep? Characterizing the Prevalence of LLM-Generated Malicious Emails," in Proc. 2025 ACM Internet Measurement Conf. (IMC '25), Madison, WI, USA, Oct. 2025. doi: 10.1145/3730567.3732922.

- [18] D. Aldam, "AI-powered Phishing: The Current Landscape and Future Projections," *XRDS: Crossroads*, ACM Mag. Students, vol. 31, no. 4, pp. 18–21, Summer 2025. doi: 10.1145/3744693.
- [19] T. Yu, C. Ye, Z. Yang, Z. Zhou, C. Tang, Z. Tao, J. Zhang, K. Wang, L. Zhou, Y. Yang, and T. Bi, "SEAR: A Multimodal Dataset for Analyzing AR-LLM-Driven Social Engineering Behaviors," in *Proc. 33rd ACM Int. Conf. Multimedia (MM '25)*, Dublin, Ireland, Oct. 2025. doi: 10.1145/3746027.3758245.
- [20] R. Nair, F. Abbasi, and S. Pervez, "PhishEmailLLM: A Meta Model Approach to Detect Phishing Emails by Leveraging LLMs and Machine Learning Models," in *Proc. 2025 Australasian Comput. Sci. Week (ACSW 2025)*, Brisbane, QLD, Australia, Feb. 2025. doi: 10.1145/3727166.3727169.
- [21] N. Costa, J. Cecílio, R. Salgueiro, M. Rosa, and D. Domingos, "LLM-based Framework for Email Classification and Phishing Detection," *LASIGE*, Faculdade de Ciências, Universidade de Lisboa.
- [22] Q. H. Nguyen, T. Wu, V. Nguyen, X. Yuan, J. Xue, and C. Rudolph, "Utilizing Large Language Models with Human Feedback Integration for Generating Dedicated Warning for Phishing Emails," in *Proc. 2nd ACM Workshop Secure Trustworthy Deep Learning Syst. (SecTL '24)*, Singapore, Jul. 2024. doi: 10.1145/3665451.3665531.
- [23] S. Shukla and O. Mirzaei, "Different Victims, Same Layout: Email Visual Similarity Detection for Enhanced Email Protection," in *Proc. 2024 ACM SIGSAC Conf. Comput. Commun. Security (CCS '24)*, Salt Lake City, UT, USA, Dec. 2024. doi: 10.1145/3658644.3691381.
- [24] B. E. Tuck, "LLMs Under Attack: Understanding the Adversarial Mindset," in *Proc. 11th ACM Int. Workshop Security Privacy Analytics (IWSPA '25)*, Pittsburgh, PA, USA, Jun. 2025. doi: 10.1145/3716815.3729018.
- [25] H. Cai, A. Arunasalam, L. Y. Lin, A. Bianchi, and Z. B. Celik, "Rethinking How to Evaluate Language Model Jailbreak," in *Proc. 18th ACM Workshop Artif. Intell. Security (AISeC '25)*, Taipei, Taiwan, Oct. 2025. doi: 10.1145/3733799.3762966.
- [26] C. Zhang, R. Pal, C. Nicholson, and M. Siegel, "(Gen)AI versus (Gen)AI in Industrial Control Cybersecurity," in *Proc. 2024 Winter Simulation Conf. (WSC 2024)*, Orlando, FL, USA, Dec. 2024.
- [27] C. Wang et al., "Survey on Factuality in Large Language Models," *ACM Comput. Surv.*, vol. 58, no. 1, Art. 13, Sep. 2025. doi: 10.1145/3742420.
- [28] Z. Tan, S. Wang, T. Chen, J. Ma, J. Li, and H. Liu, "Explaining the 'Unexplainable' Large Language Models," in *Proc. 19th ACM Int. Conf. Web Search Data Mining (WSDM '26)*, Boise, ID, USA, Feb. 2026. doi: 10.1145/3773966.3777913.
- [29] P. J. Denning, "In Large Language Models We Trust?" *Commun. ACM*, vol. 68, no. 6, pp. 24–25, Jun. 2025. doi: 10.1145/3726009.
- [30] Y. Yang, B. Xu, X. Gao, and H. Sun, "Context-Enhanced Vulnerability Detection Based on Large Language Models," *ACM Trans. Softw. Eng. Methodol.*, published Dec. 2025. doi: 10.1145/3779222.

- [31] M. A. El yagouby, A. Lahmadi, M. Zakroum, O. Festor, and M. Ghogho, "LLM-CVX: A Benchmarking Framework for Assessing the Offensive Potential of LLMs in Exploiting CVEs," in Proc. 18th ACM Workshop Artif. Intell. Security (AISeC '25), Taipei, Taiwan, Oct. 2025. doi: 10.1145/3733799.3762978.
- [32] W. Lee, J. Hur, and D. Kim, "Beneath the Phishing Scripts: A Script-Level Analysis of Phishing Kits and Their Impact on Real-World Phishing Websites," in Proc. 19th ACM Asia Conf. Comput. Commun. Security (ASIA CCS '24), Singapore, Jul. 2024. doi: 10.1145/3634737.3657013.
- [33] W. Yan, S. Chattopadhyay, L. Zhang, and A. Amresh, "Integrating Large Language Models with Cybersecurity Education," in Proc. 57th ACM Tech. Symp. Comput. Sci. Educ. V.2 (SIGCSE TS 2026), St. Louis, MO, USA, Feb. 2026. doi: 10.1145/3770761.3777269.